

process launched by a user could do what the user could. This was one of the reasons why using your computer as an administrator was risky. Integrity Levels introduced a ‘per object’ protection where each object in Windows was marked with a certain integrity level. More important the file/object, higher the integrity level it possessed. The (in)famous UAC in Windows Vista actually determined the maximum integrity level of a process running under a user account without prompting the user for permission. Even the processes launched by an administrator had access to only moderate integrity level objects.

So, while an admin user could read and modify an important file, a process launched by him would not be able to do either, without first asking for permission (well, according to the UAC settings). In Windows Vista, every file and registry key was marked with an integrity level and the trend has continued since then.

DEP and ASLR

A large part of security attacks are sourced from the possibility of executing code that can be randomly injected into the memory (RAM). The DEP (Data Execution Prevention) feature built into most x86 and x86-64 systems disallows execution of parts of memory marked as non-executable. Without DEP, a malicious hacker could execute just about anything he was able to inject into the system memory. DEP support was introduced in Windows XP Service Pack 2 to prevent such a case. Hackers decided to counter this with ‘return-to-libc’ style attacks whereby they’d execute a system library function to execute the injected code in turn. All of this is possible because the locations of libraries can be predicted.

How code injection works

Typically, code injection is done by inputting a code into a program which expects some data as an input. For example, if a web page asks you for your name in a textbox and prints the same wrapped in a tag, then inputting `Digit` in the textbox will cause the page to send back `<strong>Digit</strong>` to the browser. If however you entered

```
• Digit <script type="text/javascript"> document.
location='http://www.thinkdigit.com/'; </script>
```

in the box then the page will send back: